

# Head to Toe Brands SharePoint Infrastructure & Development Guide

## Head to Toe Brands SharePoint Infrastructure & Development Guide

**Version:** 1.0

**Research date:** May 16, 2026, America/Chicago

**Scope:** SharePoint Online, Microsoft Teams, Viva Connections, SPFx, PnP PowerShell, Microsoft Graph, GitHub Actions, OIDC federation, Microsoft 365 backup/recovery.

---

### 1. Executive summary

Head to Toe Brands should treat SharePoint as the portfolio operating layer for knowledge, documents, intranet pages, brand resources, franchise collaboration, governance, and Microsoft 365 application integration. The recommended model is a modern SharePoint hub-and-spoke ecosystem with one or more brand hubs, site collections for each distinct unit of work, and Microsoft Teams mapped deliberately to the collaboration layer.

The platform should be built as infrastructure and content configuration managed through a GitHub repository. Every deployment should run through GitHub Actions with OpenID Connect federation into Microsoft Entra ID. The workflow should avoid stored client secrets, certificates, personal access tokens, or long-lived service-account passwords. Instead, GitHub requests short-lived identity tokens at job runtime, and Microsoft Entra only accepts those tokens when they match the exact repository, branch, environment, and workflow conditions that HTTP approves.

The full strategy is:

1. Use SharePoint hubs for portfolio navigation, brand consistency, search roll-up, content roll-up, and user wayfinding.
2. Use separate SharePoint site collections for brands, departments, franchise support, training, operations, documents, and private collaboration.
3. Use Microsoft Entra groups as the single source of audience and permission membership.
4. Use audience targeting for presentation and personalization, not security.
5. Use inherited permissions by default; document every permission break.
6. Use SPFx only where native SharePoint, Microsoft Lists, Power Apps, Viva Connections, or PnP provisioning cannot meet the need.
7. Use GitHub Actions OIDC, environment protection, branch protection, PnP PowerShell, Microsoft Graph, and app registrations with least privilege.
8. Build rollback into every deployment by saving the prior templates, packages, configuration snapshots, and app package versions before production changes.

9. Use Microsoft 365 Backup, retention policies, version history, recycle bins, and documented runbooks for operational recovery.

This is an enterprise governance system, not just a SharePoint site build. The value is a stable digital operating system for the entire brand portfolio.

---

## 2. What the platform does, how it works, and why it matters

### 2.1 What it does

The HTT SharePoint ecosystem provides:

- A central digital workplace for brand operations.
- Audience-targeted pages for owners, corporate, managers, field staff, vendors, and leadership.
- Document libraries for SOPs, training, HR, marketing, brand assets, and franchise operations.
- Teams-connected collaboration spaces for operational channels and moderated communications.
- Viva Connections entry points for mobile and employee-facing cards.
- SPFx extensions where native SharePoint needs a custom component.
- GitHub-managed infrastructure for repeatable, reviewable, and reversible deployments.
- Compliance, backup, recovery, and audit practices for long-term stability.

### 2.2 How it works

The core runtime is Microsoft 365:

- **SharePoint Online** stores pages, files, lists, brand assets, templates, news, and web parts.
- **Microsoft Entra ID** stores user and group identity.
- **Microsoft Teams** provides channels, chats, meetings, files, and operational collaboration.
- **Microsoft Graph** exposes APIs for groups, users, SharePoint, Teams, and governance automation.
- **PnP PowerShell** provisions SharePoint sites, templates, pages, navigation, app catalog packages, and configuration.
- **SPFx** builds custom web parts, application customizers, and Teams tabs/personal apps.
- **GitHub Actions** builds, tests, deploys, audits, and rolls back.
- **OIDC federation** replaces stored secrets with short-lived trusted workload identity.

### 2.3 What it offers the HTT ecosystem

The business value is a consistent operating platform across the full brand portfolio:

- Faster franchise onboarding.

- Fewer scattered documents.
  - Reduced permissions drift.
  - Consistent brand governance.
  - Role-specific user experience.
  - Measurable site health.
  - Safer deployment practices.
  - Better disaster recovery.
  - Repeatable site provisioning for new brands, markets, stores, and initiatives.
- 

### 3. Source-backed platform facts

The design choices in this guide are based on current Microsoft, GitHub, and PnP documentation.

SharePoint hub sites are designed as the connective tissue for families of team sites and communication sites. Microsoft recommends separate site collections for distinct units of work because this supports governance and change better than old subsite structures. Hub sites provide shared navigation and branding, content/search roll-up, and a home destination for the hub. [S1]

Audience targeting in SharePoint can be applied to navigation links, pages, news, highlighted content, quick links, and related web parts. Microsoft Entra groups, Microsoft 365 groups, security groups, and dynamic groups are supported. Targeting personalizes content; it does not secure confidential content. [S2] [S3]

Teams and SharePoint are tightly connected. Each team is backed by a Microsoft 365 group. Files in standard channels use folders in the parent SharePoint site, while private and shared channels get separate SharePoint sites. Microsoft recommends managing access through Teams for the best user experience. [S4]

GitHub OIDC allows workflows to obtain short-lived tokens from a cloud provider without storing long-lived cloud credentials in GitHub. Azure Login with OIDC requires a federated identity credential on a Microsoft Entra app or user-assigned managed identity. [S5] [S6]

PnP PowerShell supports federated identity for GitHub Actions and Azure DevOps pipelines through Connect-PnPOnline -FederatedIdentity. The documentation currently notes this option as available from a nightly release, so HTT should pin and test the exact version before production use. [S7]

SPFx is Microsoft's client-side SharePoint development model. Current guidance shows SPFx v1.22.x using Node.js v22 LTS and React 17.0.1. SPFx packages are deployed through the SharePoint app catalog and approved by an administrator. [S8] [S9]

Microsoft 365 Backup provides service-boundary backup and restore capabilities for SharePoint, OneDrive, and Exchange. For OneDrive and SharePoint, restore points are available at high frequency for up to two weeks and then weekly out to 52 weeks. [S10] [S11]

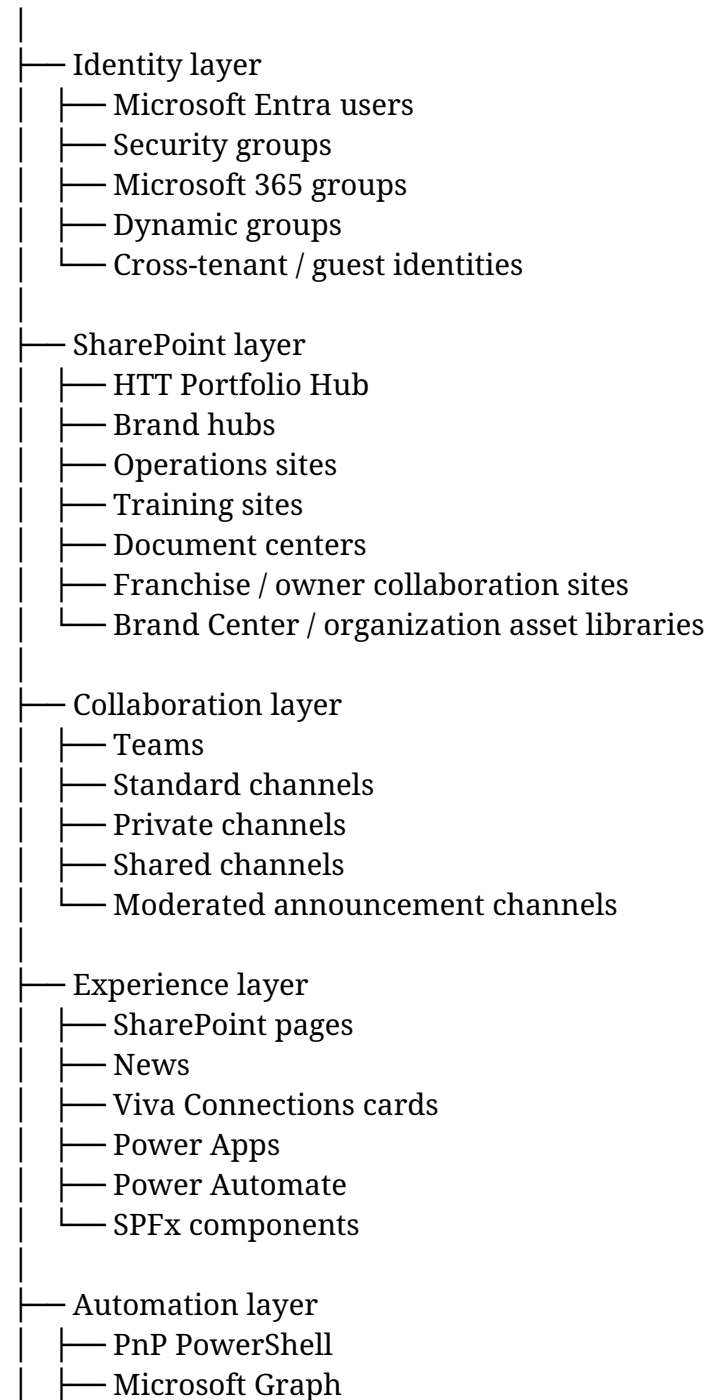
SharePoint and OneDrive retention policies still rely on the first- and second-stage recycle bins for a combined 93-day recycle-bin path when content is deleted. [S12]

---

## 4. Reference architecture

### 4.1 Logical architecture

Head to Toe Brands Microsoft 365 tenant





## 4.2 Recommended hub model

The top level should avoid a single monolithic site. HTT should use a portfolio hub and then child brand hubs or brand spokes.

| Layer        | Site type       | Purpose         |
|--------------|-----------------|-----------------|
| Portfolio    | Hub             | Enterprise nav  |
| Brand        | Hub or spoke    | Brand ops       |
| Department   | Team site       | Collaboration   |
| Training     | Learning site   | Enablement      |
| SOPs         | Document center | Controlled docs |
| Brand assets | Communication   | Assets          |
| Franchise    | Team site       | Owner collab    |

Each site is a site collection. This avoids subsite governance problems and lets HTT reorganize brands or functions without breaking URL hierarchy or applying unwanted policies everywhere.

## 4.3 Site pattern

Each site should have:

- A clear owner.
- A business purpose.
- An audience model.
- A default permission model.
- Retention labels.
- Sensitivity label.
- Metadata schema.
- Review cadence.
- A template in source control.
- A Teams relationship decision.

- A recovery runbook.
- 

## 5. Information architecture principles

### 5.1 Site rules

1. One site per business unit of work.
2. One hub per major navigation family.
3. No classic subsites for new work.
4. No deep folder sprawl as the primary organizing model.
5. Use libraries, metadata, content types, and views.
6. Use page templates for repeatable experiences.
7. Use SharePoint search as a designed experience, not an afterthought.
8. Keep permissions inherited unless content is truly confidential.
9. Use Teams for active collaboration and SharePoint for managed knowledge.
10. Store every provisioning decision in source control.

### 5.2 Navigation rules

Navigation should be designed around user tasks, not the org chart alone. Each nav item must answer one of these questions:

- Who needs it?
- What are they trying to do?
- What group controls visibility?
- What site or library owns the content?
- What happens if the group membership changes?

Use audience targeting for links that only make sense to certain roles, but do not use targeting as a replacement for permissions.

### 5.3 Page rules

A SharePoint page should have one main audience question. For example:

- “What does a franchise owner need today?”
- “What does a salon manager need before opening?”
- “What does corporate need to review weekly?”
- “What does a new stylist need for onboarding?”

If a page tries to answer too many audience questions, split it into multiple pages or use clearly targeted sections.

---

## 6. Document infrastructure best practices

### 6.1 Library design

Use document libraries by purpose, lifecycle, and governance. Do not create one mega-library for every file in a brand.

| Library        | Content    | Owner      |
|----------------|------------|------------|
| SOP Library    | SOPs       | Operations |
| Training       | Lessons    | L&D        |
| Brand Assets   | Logos      | Marketing  |
| HR Forms       | Forms      | HR         |
| Franchise Docs | Owner docs | Franchise  |
| Legal          | Contracts  | Legal      |

Each library should define:

- Required metadata.
- Content type set.
- Default retention label.
- Sensitivity label policy.
- Versioning settings.
- Approval settings.
- Review cadence.
- Archival behavior.
- Restore owner.

### 6.2 Content types

Use content types when documents need different metadata, review cycles, or compliance behaviors.

Recommended content types:

- SOP.
- Training module.
- Brand asset.
- Policy.
- Franchise agreement.
- Store launch checklist.
- Marketing campaign asset.
- Vendor document.
- Incident record.
- Announcement.

### 6.3 Metadata

Recommended metadata fields:

| Field           | Type    | Example    |
|-----------------|---------|------------|
| Brand           | Choice  | DCE        |
| Function        | Choice  | Training   |
| Region          | Choice  | Texas      |
| Audience        | Managed | Owners     |
| Lifecycle       | Choice  | Active     |
| Owner           | Person  | Jamie      |
| Review date     | Date    | 2026-08-01 |
| Confidentiality | Choice  | Internal   |
| Version         | Text    | v2.1       |

Avoid long, ambiguous fields. Use managed metadata where values must stay consistent across brands.

### 6.4 Folder strategy

Folders are acceptable for familiar browsing, but they should not replace metadata. Recommended pattern:

SOP Library

- |— Front Desk
- |— Extensions
- |— Inventory
- |— Sanitation
- |— Customer Recovery

Metadata still controls search, filtering, retention, and views.

### 6.5 Versioning and approvals

Recommended default:

- Major versioning enabled.
- Minor versioning for controlled SOPs.
- Require approval for policy/SOP libraries.
- Keep version limits appropriate to storage and recovery needs.
- Use checkout only for high-control documents.
- Use Power Automate approval only where human approval is needed.



6.6 Retention and recovery alignment

Retention is not the same as backup. Retention preserves content for compliance. Backup restores operational state after incidents. Use both.

Minimum pattern:

- Microsoft 365 Backup for key SharePoint sites.
  - Purview retention for regulated content.
  - Version history for document mistakes.
  - Recycle bins for deletion recovery.
  - Site template snapshots for configuration rollback.
  - App package version retention for SPFx rollback.
- 

7. Audience targeting and identity model

7.1 Primary principle

Group membership drives the experience. User attributes can refine targeting, but should not be the main targeting system unless the attribute quality is audited.

Use Microsoft Entra groups for:

- SharePoint audience targeting.
- Viva Connections cards.
- Navigation links.
- Page visibility.
- News targeting.
- Power Apps role logic.
- Teams membership policies.

7.2 Recommended role taxonomy

| Role            | Group                | Usage          |
|-----------------|----------------------|----------------|
| HTT Admin       | HTT-Admins           | Full control   |
| Executive       | HTT-Leadership       | Strategy       |
| Brand Lead      | HTT-Brand-Leads      | Brand ops      |
| Franchise Owner | HTT-Franchise-Owners | Owner content  |
| Store Manager   | HTT-Managers         | Ops content    |
| Staff           | HTT-Staff            | Daily work     |
| Corporate       | HTT-Corporate        | Shared ops     |
| Vendor          | HTT-Vendors          | Limited access |

7.3 Dynamic groups

Dynamic groups should be used when a membership rule is stable and testable. Examples:

- department == "Operations"
- companyName == "Head to Toe Brands"
- mail endsWith "@httbrands.com"
- extensionAttribute1 == "DCE"
- employeeType == "FranchiseOwner"

Before using a dynamic group in production, run an attribute completeness audit. A dynamic group based on a dirty attribute will create a broken user experience.

## 7.4 Targeting surfaces

| Surface             | Use            |
|---------------------|----------------|
| Hub nav             | Role links     |
| Footer nav          | Support links  |
| Pages               | Admin pages    |
| News                | Role updates   |
| Quick links         | Shortcuts      |
| Highlighted content | Dynamic docs   |
| Viva cards          | Mobile actions |
| Events              | Role events    |

## 7.5 Targeting is not security

Audience targeting filters what users see in the user experience. It is not a confidentiality boundary. If a document or page is confidential, secure it with permissions, sensitivity labels, and retention policies.

# 8. Permissions and security model

## 8.1 North star

Inherit permissions unless there is a documented confidentiality reason to break inheritance.

Use audience targeting for visibility. Use permissions for security. Use retention for compliance. Use backup for recovery. Use audits for trust.

## 8.2 Default permission model

| Principal       | Role         | Scope          |
|-----------------|--------------|----------------|
| Site owners     | Full control | Site           |
| Content editors | Edit         | Libraries      |
| Members         | Contribute   | Team sites     |
| Visitors        | Read         | Comms sites    |
| Vendors         | Restricted   | Specific sites |

| Principal  | Role     | Scope        |
|------------|----------|--------------|
| App deploy | Selected | Target sites |

### 8.3 Permission breaks

A permission break is allowed only when all are true:

1. Content is confidential.
2. Audience targeting is insufficient.
3. The break has an owner.
4. The break has a reason.
5. The break has a review date.
6. The break is recorded in permission-breaks.csv.
7. The weekly audit can verify it.

### 8.4 Application access

For app-only automation, use selected permissions wherever possible. Microsoft Graph Selected permissions allow application access at site, list, item, folder, or file level. A selected permission has no access until the resource permission is explicitly assigned. [S13]

Recommended approach:

- Avoid tenant-wide Sites.FullControl.All for routine deploys.
- Use Sites.Selected for SharePoint deploy apps.
- Grant site-level write or fullcontrol only to the site collections the app deploys.
- Split dev and prod app registrations.
- Split Teams governance app from SharePoint deploy app.
- Split read-only audit app from deploy app.

## 9. Teams integration and moderation

### 9.1 Teams and SharePoint relationship

Teams is the collaboration layer. SharePoint is the document and knowledge layer. Each Microsoft Team is connected to a Microsoft 365 group, and files in Teams are stored in SharePoint.

Important channel behavior:

- Standard channels share the parent team SharePoint site.
- Private channels receive a separate SharePoint site.
- Shared channels receive a separate SharePoint site.
- Channel site permissions should be managed through Teams.

## 9.2 Channel strategy

| Channel type | Use               |
|--------------|-------------------|
| Standard     | Team-wide ops     |
| Private      | Restricted team   |
| Shared       | Cross-org collab  |
| Announcement | Moderated updates |
| Support      | Intake and help   |

## 9.3 Moderation model

For announcement and policy channels:

- Only moderators start posts.
- Replies can be allowed or limited.
- Bots and connectors are explicitly approved.
- Team owners are default moderators.
- Channel moderators are role-based.

Graph currently exposes channelModerationSettings in beta, which means production use must be treated carefully. Microsoft states Graph beta APIs are subject to change and not supported for production applications. For governance automation, use beta only in controlled runbooks with explicit change review, or configure moderation through Teams UI/admin processes until the target API reaches v1.0. [S14]

## 9.4 Moderation API example

PATCH <https://graph.microsoft.com/beta/teams/{team-id}/channels/{channel-id}>

Content-Type: application/json

```
{
  "moderationSettings": {
    "userNewMessageRestriction": "moderators",
    "replyRestriction": "everyone",
    "allowNewMessageFromBots": true,
    "allowNewMessageFromConnectors": true
  }
}
```

The least-privileged application permission shown in Microsoft's beta channel update documentation is ChannelSettings.ReadWrite.Group, using resource-specific consent. [S15]

## 9.5 Teams app development

For new Teams applications and agents, Microsoft now recommends the Teams SDK or Microsoft 365 Agents SDK depending on the scenario. TeamsFx is in deprecation mode. For SPFx-based Teams tabs, use SPFx when the solution is a SharePoint-hosted UI component. [S16]

SPFx can expose web parts as Teams tabs and personal apps. The web part runs in the context of the underlying SharePoint site. Use the SPFx-provided Teams JS SDK context; do not install and initialize custom Teams JS SDK versions inside SPFx. [S17] [S18]

---

## 10. Application ecosystem capabilities

### 10.1 SharePoint native capabilities

SharePoint offers:

- Communication sites.
- Team sites.
- Hub sites.
- Modern pages.
- News.
- Document libraries.
- Microsoft Lists.
- Metadata and content types.
- Search.
- Page templates.
- Organization assets.
- Brand Center.
- Versioning.
- Approvals.
- Audience targeting.
- App catalog.

### 10.2 Microsoft Teams capabilities

Teams offers:

- Channel-based collaboration.
- Meetings.
- Files backed by SharePoint.
- Tabs.
- Apps.
- Bots.
- Agents.
- Channel moderation.
- Shared and private collaboration spaces.

### 10.3 Viva Connections capabilities

Viva Connections adds mobile/employee home experiences:

- Role-targeted cards.
- Resource links.
- SharePoint news.
- Mobile entry points.
- Employee action dashboard.

#### 10.4 Power Platform capabilities

Use Power Platform when the need is workflow or forms:

- Power Apps for intake, request, and review forms.
- Power Automate for approval and notification workflows.
- Power BI for reporting dashboards.
- Dataverse for structured enterprise data.
- Microsoft Lists for lightweight operational tracking.

#### 10.5 SPFx capabilities

Use SPFx for custom UI:

- Web parts.
- Application customizers.
- Field customizers.
- Command sets.
- Teams tabs.
- Personal apps.
- Graph-backed components.
- Audience-aware dashboards.

#### 10.6 Microsoft Graph capabilities

Use Microsoft Graph for automation:

- User and group lookups.
  - SharePoint file/list/site operations.
  - Teams channel settings.
  - Permission audits.
  - Site access assignment.
  - Notification and reporting workflows.
- 

### 11. SPFx development model

#### 11.1 When to use SPFx

Use SPFx when:

- Native web parts cannot represent the data.
- UI needs custom role-based behavior.
- A reusable component is needed across sites.
- Teams tab integration is required.
- A custom header/footer/command is required.
- A Graph-powered dashboard is required.

Do not use SPFx for:

- Simple pages.
- Simple links.
- Basic document libraries.
- Basic forms that Power Apps can handle.
- Workflows that Power Automate can handle.
- Static branding that Brand Center can handle.

## 11.2 Toolchain

| Tool           | Version    |
|----------------|------------|
| Node.js        | v22 LTS    |
| SPFx           | v1.22.x    |
| React          | 17.0.1     |
| TypeScript     | SPFx table |
| Fluent UI      | v9         |
| PnP PowerShell | pinned     |
| Playwright     | current    |
| axe-core       | current    |

SPFx v1.22.x introduces the newer Heft-based toolchain. Pin versions and verify compatibility before upgrading. [S9]

## 11.3 SPFx package deployment

SPFx packages build to .sppkg packages and are deployed to the SharePoint app catalog. Microsoft states tenant administrators approve SPFx packages in the app catalog. App catalog packages should be retained because SPFx itself does not provide a special backup/restore feature; the app catalog is a SharePoint library with versioning and recycle bin behavior. [S8]

## 11.4 Component standards

Every SPFx component should define:

- Component purpose.
- Supported hosts.
- Graph scopes.
- Audience assumptions.

- Data sources.
- Error states.
- Loading states.
- Accessibility tests.
- Telemetry events.
- Rollback behavior.

## 11.5 SPFx and Teams tabs

For a web part to run in Teams, include supported hosts:

```
{
  "supportedHosts": ["SharePointWebPart", "TeamsTab", "TeamsPersonalApp"]
}
```

Then deploy to the tenant app catalog and sync with Teams if using the SharePoint-generated Teams app package.

---

## 12. GitHub repository model

### 12.1 Recommended repository

```
htt-sharepoint-platform/
├── .github/
│   ├── workflows/
│   │   ├── pr-validate.yml
│   │   ├── deploy-dev.yml
│   │   ├── deploy-uat.yml
│   │   ├── deploy-prod.yml
│   │   ├── rollback.yml
│   │   ├── permission-audit.yml
│   │   └── backup-snapshot.yml
│   └── docs/
│       ├── architecture/
│       ├── runbooks/
│       ├── decisions/
│       └── standards/
├── sites/
│   ├── portfolio-hub/
│   ├── brand-dce/
│   ├── brand-halo/
│   ├── training/
│   └── operations/
└── templates/
```



```

|   |— pnp/
|   |— pages/
|   |— navigation/
|   |— lists/
|— spfx/
|   |— packages/
|   |— webparts/
|   |— extensions/
|— tokens/
|   |— htt.tokens.json
|   |— brands/
|— scripts/
|   |— deploy/
|   |— audit/
|   |— rollback/
|   |— bootstrap/
|— tests/
|   |— accessibility/
|   |— smoke/
|   |— visual/
|   |— unit/
|— references/
|   |— site-inventory.csv
|   |— group-inventory.csv
|   |— permission-breaks.csv
|   |— app-registrations.csv
|— README.md

```

## 12.2 Branching

| Branch    | Purpose | Deploy |
|-----------|---------|--------|
| feature/* | Work    | No     |
| develop   | Dev     | Yes    |
| release/* | UAT     | Yes    |
| main      | Prod    | Yes    |

## 12.3 GitHub environments

Use GitHub environments:

- dev
- uat
- prod
- rollback-prod

GitHub environment protection rules can require approvals, wait timers, and branch restrictions before a job can access environment secrets or proceed. [S19]

## 12.4 Required repository controls

- Branch protection on main.
  - Required status checks.
  - Required code review.
  - Required signed commits where feasible.
  - No direct pushes to main.
  - No unpinned third-party actions.
  - Minimal GITHUB\_TOKEN permissions.
  - OIDC only for cloud auth.
  - Environment protection for prod.
  - Artifact retention for rollback.
- 

## 13. OIDC federation and app registrations

### 13.1 Principle

No long-lived credentials in GitHub.

Do not store:

- Client secrets.
- Certificates.
- Passwords.
- Personal access tokens.
- Static Graph tokens.
- Static SharePoint tokens.

GitHub OIDC allows jobs to exchange a workflow identity for a short-lived cloud token after the cloud provider validates claims. [S5]

### 13.2 App registration pattern

Use a separate app registration per environment and function.

| App                 | Env  | Purpose |
|---------------------|------|---------|
| htt-spo-deploy-dev  | Dev  | Deploy  |
| htt-spo-deploy-uat  | UAT  | Deploy  |
| htt-spo-deploy-prod | Prod | Deploy  |
| htt-spo-audit       | All  | Audit   |
| htt-teams-gov       | All  | Teams   |
| htt-backup-report   | All  | Reports |

Each app registration creates a service principal in the tenant. The service principal is the enterprise application instance that receives permissions and can be used in federation.

### 13.3 Federated credential subject examples

Use exact subject scoping.

```
repo:Head-To-Toe-Brands/htt-sharepoint-platform:environment:prod
repo:Head-To-Toe-Brands/htt-sharepoint-platform:ref:refs/heads/main
repo:Head-To-Toe-Brands/htt-sharepoint-platform:pull_request
```

Production deploy federation should be scoped to the prod GitHub environment and the main branch. Dev federation can be scoped to develop.

### 13.4 GitHub workflow permissions

Only the deploy job should request OIDC.

permissions:  
 contents: read  
 id-token: write

Do not grant broad write permissions unless a workflow truly needs them.

### 13.5 SharePoint app permissions

Use Selected permissions first.

| Scope                             | Use         |
|-----------------------------------|-------------|
| Sites.Selected                    | Site deploy |
| Lists.SelectedOperations.Selected | List ops    |
| Files.SelectedOperations.Selected | File ops    |
| Group.Read.All                    | Audit       |
| User.Read.All                     | Audit       |
| ChannelSettings.ReadWrite.Group   | Teams gov   |

Avoid tenant-wide permissions for routine pipelines. If a bootstrap workflow temporarily requires Sites.FullControl.All, isolate it to a break-glass app registration, lock it behind manual approval, and remove or disable it after bootstrap.

### 13.6 Granting site-selected permission

Example Graph request:

```
POST https://graph.microsoft.com/v1.0/sites/{siteId}/permissions
Content-Type: application/json
```

```
{
```

```
"roles": ["write"],
"grantedToIdentities": [
  {
    "application": {
      "id": "{app-client-id}",
      "displayName": "htt-spo-deploy-prod"
    }
  }
]
}
```

Grant write where possible. Grant fullcontrol only when provisioning truly requires it.

---

## 14. CI/CD pipeline design

### 14.1 Pipeline stages

Feature branch

↓

Pull request

↓

PR validation

- |— lint
- |— dependency audit
- |— SPFx build
- |— PnP template validation
- |— accessibility checks
- |— Playwright smoke tests
- |— visual diff

↓

Review approval

↓

Merge to develop

↓

Deploy dev

↓

Promote to UAT

↓

Deploy UAT

↓

Manual approval

↓

Deploy prod

- └─ export pre-deploy snapshot
- └─ upload SPFx package
- └─ apply PnP templates
- └─ update pages/nav/audience
- └─ run smoke tests
- └─ post Teams notification

## 14.2 PR validation workflow

name: PR validation

on:

pull\_request:

branches: [develop, main]

permissions:

contents: read

jobs:

validate:

runs-on: ubuntu-latest

steps:

- uses: actions/checkout@v4

- uses: actions/setup-node@v4

with:

node-version: 22

cache: npm

- name: Install dependencies

run: npm ci

- name: Build design tokens

run: npm run tokens:build

- name: Build SPFx

run: |

cd spfx

npm ci

npx gulp clean

npx gulp bundle --ship

npx gulp package-solution --ship

- name: Validate PnP templates

shell: pwsh

```
run: |  
  Install-Module PnP.PowerShell -Force -Scope CurrentUser  
  Get-ChildItem templates/pnp -Recurse -Filter *.xml | ForEach-Object {  
    Write-Host "Validating $($_.FullName)"  
    # Replace with approved validation command for current PnP version.  
    [xml](Get-Content $_.FullName) | Out-Null  
  }
```

- name: Run accessibility tests

```
run: npm run test:a11y
```

- name: Run smoke tests

```
run: npm run test:smoke
```

### 14.3 Production deployment workflow

name: Deploy production

on:

push:

branches: [main]

workflow\_dispatch:

permissions:

contents: read

id-token: write

env:

TENANT\_NAME: httbrands.onmicrosoft.com

SITE\_URL: https://httbrands.sharepoint.com/sites/portfolio-hub

jobs:

deploy:

runs-on: ubuntu-latest

environment: prod

concurrency:

group: sharepoint-prod

cancel-in-progress: false

steps:

- uses: actions/checkout@v4

- uses: actions/setup-node@v4

with:

node-version: 22

- cache: npm
- name: Install dependencies  
run: npm ci
- name: Build SPFx package  
run: |  
    cd spfx  
    npm ci  
    npx gulp clean  
    npx gulp bundle --ship  
    npx gulp package-solution --ship
- name: Install PnP PowerShell  
shell: pwsh  
run: |  
    Install-Module PnP.PowerShell -Force -Scope CurrentUser -AllowPrerelease
- name: Pre-deploy snapshot  
shell: pwsh  
env:  
    ENTRAID\_CLIENT\_ID: \${vars.PROD\_DEPLOY\_CLIENT\_ID}  
run: |  
    ./scripts/deploy/export-snapshot.ps1 `  
    -Tenant \$env:TENANT\_NAME `  
    -SiteUrl \$env:SITE\_URL `  
    -OutDir "out/snapshots/\${github.run\_id}"
- name: Deploy SharePoint  
shell: pwsh  
env:  
    ENTRAID\_CLIENT\_ID: \${vars.PROD\_DEPLOY\_CLIENT\_ID}  
run: |  
    ./scripts/deploy/deploy-sharepoint.ps1 `  
    -Tenant \$env:TENANT\_NAME `  
    -SiteUrl \$env:SITE\_URL `  
    -Environment prod
- name: Run post-deploy smoke tests  
run: npm run test:prod-smoke
- name: Upload rollback artifacts  
uses: actions/upload-artifact@v4

```

with:
  name: prod-rollback-${{ github.run_id }}
  path: |
    out/snapshots/${{ github.run_id }}
    spfx/sharepoint/solution/*.sppkg

```

#### 14.4 PnP federated connection script

```

param(
  [Parameter(Mandatory)] [string] $Tenant,
  [Parameter(Mandatory)] [string] $SiteUrl
)

```

*# PnP currently documents -FederatedIdentity for GitHub Actions and Azure DevOps.  
# Pin and test the exact approved version before production use.*

```

Connect-PnPOnline `
  -Url $SiteUrl `
  -Tenant $Tenant `
  -ClientId $env:ENTRAID_CLIENT_ID `
  -FederatedIdentity `
  -ValidateConnection

```

Do not use -AccessToken as the primary connection pattern. PnP warns that manually supplied access tokens limit functionality and do not automatically refresh. [S7]

#### 14.5 Deployment script outline

```

param(
  [Parameter(Mandatory)] [string] $Tenant,
  [Parameter(Mandatory)] [string] $SiteUrl,
  [Parameter(Mandatory)] [ValidateSet('dev','uat','prod')] [string] $Environment
)

```

```

. ./scripts/deploy/connect-pnp-federated.ps1 -Tenant $Tenant -SiteUrl $SiteUrl

```

*# 1. Apply theme / tokens*

```
Invoke-PnPSiteTemplate -Path "templates/pnp/shared/theme.xml"
```

*# 2. Apply site template*

```
Invoke-PnPSiteTemplate -Path "templates/pnp/$Environment/portfolio-hub.xml"
```

*# 3. Upload SPFx package*

```
Add-PnPApp -Path "spfx/sharepoint/solution/htt-platform.sppkg" -Scope Tenant
-Overwrite
```

```
Publish-PnPApp -Identity "htt-platform.sppkg" -Scope Tenant
```



#### # 4. Apply navigation

./scripts/deploy/apply-navigation.ps1 -Environment \$Environment

#### # 5. Apply page templates and targeting metadata

./scripts/deploy/apply-pages.ps1 -Environment \$Environment

#### # 6. Verify

./scripts/deploy/verify-site.ps1 -Environment \$Environment

---

## 15. Quality gates

### 15.1 Required gates

| Gate             | Tool             | Result |
|------------------|------------------|--------|
| Token build      | Style Dictionary | Block  |
| SPFx build       | Gulp/Heft        | Block  |
| Unit tests       | Jest             | Block  |
| Ally             | axe-core         | Block  |
| Smoke            | Playwright       | Block  |
| Visual           | Playwright       | Review |
| PnP syntax       | XML/PnP          | Block  |
| Permission drift | Audit            | Alert  |

### 15.2 Accessibility standard

Minimum baseline:

- WCAG 2.2 AA.
- Keyboard navigation.
- Visible focus.
- Semantic headings.
- Accessible link text.
- Color contrast checks.
- Screen reader checks for custom SPFx.
- Reduced-motion support.
- No inaccessible icon-only controls.

### 15.3 Security gates

- No secrets in repository.
- No PATs.
- No client secrets.
- No PFX in GitHub secrets.

- No broad Graph scopes without an ADR.
  - No production deploy from unprotected branch.
  - No third-party action without review.
  - No pull\_request\_target deploy behavior.
  - No unreviewed dependency upgrades.
- 

## 16. Rollback and recovery

### 16.1 Rollback layers

| Layer         | Rollback           |
|---------------|--------------------|
| SPFx package  | Prior .sppkg       |
| Pages         | Prior PnP snapshot |
| Navigation    | Prior nav JSON     |
| Theme         | Prior theme JSON   |
| Lists         | Template delta     |
| Files         | Version history    |
| Deleted items | Recycle bin        |
| Disaster      | M365 Backup        |

### 16.2 Pre-deploy snapshot

Before every production deployment:

1. Export current site template.
2. Export navigation JSON.
3. Export page metadata.
4. Export app catalog package list.
5. Save current .sppkg package.
6. Save permission break audit.
7. Upload all artifacts.
8. Record run ID in the deployment log.

Example:

```
$stamp = Get-Date -Format "yyyyMMdd-HH:mm:ss"
```

```
$out = "out/snapshots/$stamp"
```

```
New-Item -ItemType Directory -Force -Path $out | Out-Null
```

```
Get-PnPSiteTemplate -Out "$out/site-template.pnp" -PersistBrandingFiles
```

```
Get-PnPNavigationNode -Location TopNavigationBar | ConvertTo-Json -Depth 20 | Out-File "$out/nav.json"
```

```
Get-PnPApp -Scope Tenant | ConvertTo-Json -Depth 20 | Out-File "$out/apps.json"
```

### 16.3 Rollback workflow

name: Rollback production

on:

workflow\_dispatch:

inputs:

artifact\_run\_id:

description: "Run ID containing rollback artifacts"

required: true

rollback\_reason:

description: "Reason"

required: true

permissions:

contents: read

id-token: write

jobs:

rollback:

runs-on: ubuntu-latest

environment: rollback-prod

steps:

- uses: actions/checkout@v4

- name: Restore previous site state

shell: pwsh

env:

ENTRAID\_CLIENT\_ID: \${vars.PROD\_DEPLOY\_CLIENT\_ID}

run: |

./scripts/rollback/rollback-prod.ps1 `

-ArtifactRunId "\${github.event.inputs.artifact\_run\_id}" `

-Reason "\${github.event.inputs.rollback\_reason}"

### 16.4 Data recovery

Use the smallest recovery scope that solves the issue:

1. **Version history** for a bad document edit.
2. **Library restore** for mass changes in a library.
3. **Recycle bin** for deletion within the 93-day path.
4. **Microsoft 365 Backup** for ransomware, large overwrite, or broader restore.
5. **Purview/eDiscovery hold** for legal retention.
6. **Microsoft support** for severe edge cases outside normal recovery.

Microsoft 365 Backup restore points for SharePoint/OneDrive are high-frequency for up to two weeks and weekly from two to 52 weeks. [S11]

## 16.5 SPFx recovery

SPFx packages need their own package retention strategy because Microsoft states SPFx has no special backup/restore capability. Keep every production .sppkg in:

- GitHub release artifacts.
  - App catalog version history.
  - Deployment run artifact.
  - Optional immutable storage.
- 

## 17. Governance and audit model

### 17.1 Weekly audits

Run weekly:

- Permission breaks.
- Group membership drift.
- Orphaned sites.
- Unowned content.
- Expired review dates.
- Failed workflows.
- App registration permissions.
- Federated credential subjects.
- App catalog package versions.
- Teams moderation drift.

### 17.2 Monthly audits

Run monthly:

- Dynamic group accuracy.
- Site owner completeness.
- External sharing report.
- Guest users report.
- Sensitivity label coverage.
- Retention label coverage.
- Search quality review.
- User experience review by role.

### 17.3 Quarterly audits

Run quarterly:

- Full governance review.
- Disaster recovery test.

- Restore drill.
- SPFX dependency upgrade review.
- OIDC app permission review.
- Brand taxonomy review.
- Site inventory cleanup.

## 17.4 Required inventories

Keep these in source control:

- site-inventory.csv
  - group-inventory.csv
  - app-registrations.csv
  - permission-breaks.csv
  - teams-channel-inventory.csv
  - retention-policy-map.csv
  - sensitivity-label-map.csv
  - spfx-package-inventory.csv
  - runbook-index.md
- 

## 18. Runbooks

### 18.1 New brand site runbook

1. Create brand record.
2. Create Entra groups.
3. Create SharePoint site.
4. Apply site template.
5. Apply brand theme.
6. Associate to hub.
7. Configure navigation.
8. Configure libraries.
9. Configure retention labels.
10. Configure Teams.
11. Configure audience targeting.
12. Run smoke tests.
13. Add to inventory.
14. Notify owners.

### 18.2 New audience group runbook

1. Define audience need.
2. Confirm no existing group fits.
3. Create ADR.

4. Create Entra group.
5. Assign owner.
6. Add membership rules.
7. Test membership.
8. Update group inventory.
9. Apply targeting.
10. Preview pages by audience.
11. Publish.

### 18.3 Permission break runbook

1. Identify confidential content.
2. Confirm audience targeting is insufficient.
3. Approve break.
4. Record in permission-breaks.csv.
5. Apply break.
6. Run audit.
7. Add review date.
8. Notify owner.

### 18.4 Deployment failure runbook

1. Stop concurrent deployments.
2. Capture logs.
3. Identify failed stage.
4. Determine if user impact exists.
5. If no impact, fix and redeploy.
6. If impact exists, rollback.
7. Run smoke tests.
8. Post incident summary.
9. Create corrective action.

### 18.5 Ransomware / mass deletion runbook

1. Freeze affected workflows.
  2. Preserve audit evidence.
  3. Identify affected sites and libraries.
  4. Check version history and recycle bins.
  5. Use Microsoft 365 Backup for broad restore.
  6. Validate restored content.
  7. Review compromised identities.
  8. Rotate risky credentials.
  9. Update incident report.
-

## 19. Implementation roadmap

### Phase 1 — Foundation

- Confirm tenant naming.
- Confirm hub taxonomy.
- Build site inventory.
- Build group inventory.
- Create governance repo.
- Define app registrations.
- Configure GitHub environments.
- Configure OIDC federated credentials.

### Phase 2 — SharePoint baseline

- Create portfolio hub.
- Create brand hub template.
- Create document center template.
- Configure Brand Center.
- Configure organization asset libraries.
- Configure page templates.
- Configure nav targeting.

### Phase 3 — CI/CD

- Build PR validation.
- Build dev deploy.
- Build UAT deploy.
- Build prod deploy.
- Build rollback workflow.
- Build permission audit.
- Build smoke tests.

### Phase 4 — Teams and Viva

- Map Teams to sites.
- Configure moderation model.
- Add Viva Connections cards.
- Add role-targeted actions.
- Validate mobile experience.

### Phase 5 — SPFx

- Build first custom component.
- Deploy to dev.
- Test accessibility.
- Sync to Teams if needed.
- Promote through UAT/prod.

## Phase 6 — Recovery and governance

- Enable Microsoft 365 Backup.
  - Configure retention policies.
  - Run restore drill.
  - Run permission drift audit.
  - Run OIDC permission review.
  - Publish final runbooks.
- 

## 20. Key decisions

### 20.1 Recommended defaults

- Use modern site collections, not subsites.
- Use hubs for navigation and roll-up.
- Use Entra groups for audience targeting.
- Use inherited permissions by default.
- Use Sites.Selected for deploy apps.
- Use OIDC federation for CI/CD.
- Use PnP for SharePoint provisioning.
- Use SPFx only for custom UI.
- Use Microsoft 365 Backup for recovery.
- Use GitHub environment approval for prod.

### 20.2 Decisions requiring Tyler/HTT approval

- Exact tenant and repo names.
  - Brand hub count.
  - Site naming convention.
  - App registration owner list.
  - Required production reviewers.
  - Emergency break-glass process.
  - Data retention periods.
  - Guest access policy.
  - Teams moderation policy.
  - Microsoft 365 Backup licensing/billing.
- 

## 21. Starter decision records

### ADR-001: Hub-and-spoke over subsites

**Decision:** Use hub-and-spoke site collections.

**Reason:** Better governance, flexibility, and search/content roll-up.

**Rejected:** Classic subsite hierarchy.

**Consequence:** More site inventory discipline is required.



### ADR-002: OIDC over stored secrets

**Decision:** Use GitHub Actions OIDC federation.

**Reason:** No stored long-lived credentials.

**Rejected:** Client secrets, PATs, PFX secrets.

**Consequence:** Requires Entra app and federated credential governance.

### ADR-003: Sites.Selected for deploy apps

**Decision:** Use selected permissions.

**Reason:** Limits blast radius.

**Rejected:** Tenant-wide deploy app.

**Consequence:** Bootstrap grants must be managed deliberately.

### ADR-004: Audience targeting is not security

**Decision:** Use targeting for UX only.

**Reason:** Targeting filters presentation.

**Rejected:** Hiding confidential content with targeting only.

**Consequence:** Confidential content needs permissions and labels.

### ADR-005: SPFx only when native cannot solve it

**Decision:** Prefer native SharePoint, Power Platform, and Viva first.

**Reason:** Lower maintenance and faster delivery.

**Rejected:** Custom code for every component.

**Consequence:** SPFx backlog must justify business value.

---

## 22. Source references

[S1] Microsoft Learn — Planning your SharePoint hub sites. <https://learn.microsoft.com/en-us/sharepoint/planning-hub-sites>

[S2] Microsoft Support — Target content to a specific audience on a SharePoint site. <https://support.microsoft.com/en-au/office/target-content-to-a-specific-audience-on-a-sharepoint-site-68113d1b-be99-4d4c-a61c-73b087f48a81>

[S3] Microsoft Learn — Use audience targeting in Viva Connections. <https://learn.microsoft.com/en-us/viva/connections/use-audience-targeting-in-viva-connections>

[S4] Microsoft Learn — Teams and SharePoint integration. <https://learn.microsoft.com/en-us/sharepoint/teams-connected-sites>

[S5] GitHub Docs — OpenID Connect. <https://docs.github.com/actions/security-for-github-actions/security-hardening-your-deployments/about-security-hardening-with-openid-connect>

[S6] Microsoft Learn — Use Azure Login action with OpenID Connect. <https://learn.microsoft.com/en-us/azure/developer/github/connect-from-azure-openid-connect>

[S7] PnP PowerShell — Connect-PnPOnline. <https://pnp.github.io/powershell/cmdlets/Connect-PnPOnline.html>

[S8] Microsoft Learn — SharePoint Framework enterprise guidance.  
<https://learn.microsoft.com/en-us/sharepoint/dev/spfx/enterprise-guidance>

[S9] Microsoft Learn — SPFx compatibility reference.  
<https://learn.microsoft.com/en-us/sharepoint/dev/spfx/compatibility>

[S10] Microsoft Learn — Overview of Microsoft 365 Backup. <https://learn.microsoft.com/en-us/microsoft-365/backup/backup-overview>

[S11] Microsoft Learn — Restore data in Microsoft 365 Backup.  
<https://learn.microsoft.com/en-us/microsoft-365/backup/backup-restore-data>

[S12] Microsoft Learn — Retention for SharePoint and OneDrive.  
<https://learn.microsoft.com/en-us/purview/retention-policies-sharepoint>

[S13] Microsoft Learn — Selected permissions in OneDrive and SharePoint.  
<https://learn.microsoft.com/en-us/graph/permissions-selected-overview>

[S14] Microsoft Learn — channelModerationSettings resource type.  
<https://learn.microsoft.com/en-us/graph/api/resources/channelmoderationsettings>

[S15] Microsoft Learn — Update channel, Microsoft Graph beta.  
<https://learn.microsoft.com/en-us/graph/api/channel-patch>

[S16] Microsoft Learn — Tools and SDKs to build Teams apps. <https://learn.microsoft.com/en-us/microsoftteams/platform/concepts/build-and-test/tool-sdk-overview>

[S17] Microsoft Learn — Building Microsoft Teams tabs using SharePoint Framework.  
<https://learn.microsoft.com/en-us/sharepoint/dev/spfx/integrate-with-teams-introduction>

[S18] Microsoft Learn — Considerations for building for Teams using SPFx.  
<https://learn.microsoft.com/en-us/sharepoint/dev/spfx/build-for-teams-considerations>

[S19] GitHub Docs — Deployments and environments.  
<https://docs.github.com/en/actions/reference/workflows-and-actions/deployments-and-environments>